Experiment No. 13

Detect Web Application Vulnerabilities Using Various Web Application Security Tools

AIM

To detect common vulnerabilities and security misconfigurations in a target web application using a combination of web application security tools such as OWASP ZAP, Nikto, and Burp Suite.

PROCEDURE

1. Run an OWASP ZAP automated scan (spider + active scan) against the target application to obtain a baseline vulnerability report.
2. Run Nikto against the same target (nikto -h http://) to check for outdated server software, dangerous files, and known CGI vulnerabilities.
3. Use Burp Suite's Scanner (or manual testing with Repeater/Intruder) to validate and further probe any vulnerabilities flagged by the automated tools.
4. Cross-reference the findings from all three tools to eliminate false positives and confirm genuine vulnerabilities.
5. Classify each confirmed vulnerability by severity (Critical/High/Medium/Low) using a standard reference such as the OWASP Top 10.
6. Record the affected URL/parameter, the tool(s) that detected it, and a recommended remediation for each vulnerability.
7. Compile a consolidated vulnerability assessment report.

SAMPLE OUTPUT

```
Consolidated Vulnerability Report - testapp.local

1. SQL Injection (/profile.php?id=)          Detected by: ZAP, Burp   | High
2. Reflected XSS (/search.php?query=)         Detected by: ZAP, Burp   | High
3. Outdated Apache 2.4.54 w/ known CVEs       Detected by: Nikto       | Medium
4. Directory listing enabled (/backup/)       Detected by: Nikto, ZAP  | Medium
5. Missing Anti-CSRF tokens (/change_email)    Detected by: Burp, ZAP   | Medium
6. Server header discloses version info        Detected by: Nikto, ZAP  | Low

Total confirmed vulnerabilities: 6 (2 High, 3 Medium, 1 Low)
```

RESULT

A consolidated vulnerability assessment of the target web application was performed using OWASP ZAP, Nikto, and Burp Suite, cross-validating and confirming six vulnerabilities, including two High-severity issues requiring immediate remediation.